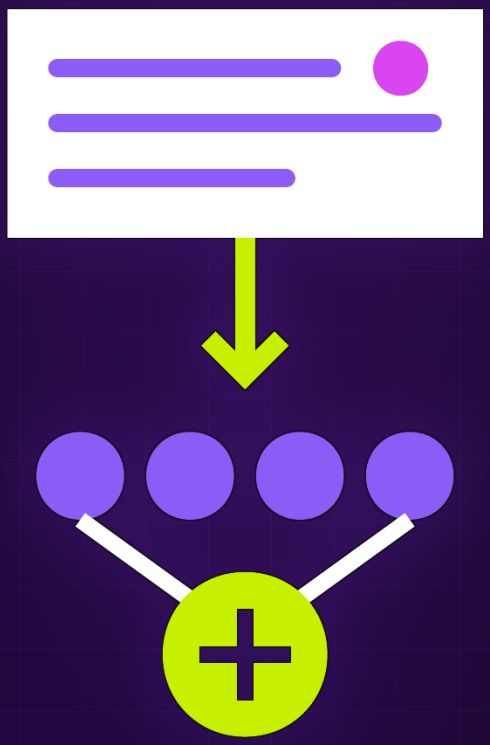
CANTO INCOGNITO POELLM C2

Hunts GitHub poem-based C2 discovery from compromised AI infrastructure.

HUNTING QUERY

CONFIDENCE: MEDIUM



REPORT DATE
11 October 2026

STATUS
Untested implementation sketch

PRIMARY PLATFORM
Microsoft Defender XDR

OPERATIONAL VALUE
8.0 / 10

EXECUTIVE ASSESSMENT

Decision, confidence and evidence boundary.

ASSESSMENT

OPERATIONAL VALUE

8.0

Hunts GitHub poem-based C2 discovery from compromised AI infrastructure.

CLASSIFICATION

Hunting query

Medium confidence. Source-supported campaign evidence; environmental prevalence is not validated.

1 primary table
1 primary query
0 production claims
4 validation gates

Evidence boundary

A repository or path match does not prove malware execution, decoded C2 use, compromise, or attribution.

BEHAVIOR AND EVIDENCE

Observed facts separated from analytical scope.

MECHANICS

#	Source-supported fact
1	Black Lotus Labs tracked PoeLLM from April 2026 across more than 3,400 affected servers.
2	The malware retrieved dash.css from GitHub and decoded four words into the current C2 IPv4 address.
3	Repository identity and filename are more durable than rotating C2 addresses.

Detection hypothesis

If the published behavior occurs in a covered endpoint or cloud workload, DeviceNetworkEvents should retain the campaign-specific evidence used by this hunt.

Unconfirmed elements

A repository or path match does not prove malware execution, decoded C2 use, compromise, or attribution.

ATT&CK: T1102.003

TELEMETRY CONTRACT

Collection prerequisites and field reliability.

TELEMETRY

REQUIRED

DeviceNetworkEvents

Microsoft Defender XDR advanced hunting coverage must retain the fields referenced by the query.

OPTIONAL ENRICHMENT

Identity, device, network, file reputation, prevalence, owner, change record, and adjacent-event context.

Requirement	Decision
Primary platform	Microsoft Defender XDR
Primary table	DeviceNetworkEvents
Query status	Untested implementation sketch
Classification	Hunting; no alerting before validation

Coverage caveat

An empty result may mean no match, missing telemetry, retention gaps, parser differences, or field sparsity.

PRIMARY KQL

Source-supported conditions with investigable output.

HUNTING

STATUS

Hunting query — Untested implementation sketch

KQL — UNTESTED

```
// Canto Incognito / PoeLLM - GitHub poem-based C2 discovery
// MITRE ATT&CK: T1102.003 - Web Service: One-Way Communication
// Platform: Microsoft Defender XDR Advanced Hunting
// Status: Hunting query - Untested implementation sketch
// Confidence: Medium
// Required telemetry: Microsoft Defender for Endpoint DeviceNetworkEvents
// Evidence: Black Lotus Labs observed PoeLLM retrieving a file named dash.css
// from a GitHub repository owned by ejejejdfbbebe to derive the current C2 IP.
// Limitation: RemoteUrl may contain only an FQDN in some events. Absence of
// results therefore does not prove absence of PoeLLM or the GitHub fetch.

DeviceNetworkEvents
| where RemoteUrl has "ejejejdfbbebe"
| where RemoteUrl endswith "dash.css"
| project
    Timestamp,
    DeviceName,
    RemoteUrl,
    RemoteIP,
    RemotePort,
    Protocol,
    InitiatingProcessFileName,
    InitiatingProcessCommandLine,
    InitiatingProcessFolderPath,
    InitiatingProcessSHA1,
    InitiatingProcessAccountName,
    ReportId
| order by Timestamp desc
```

TRIAGE AND TUNING

Human validation before response.

WORKFLOW

1

Preserve

Retain the raw event, device or account, timestamps, and campaign-matched values.

2

Confirm

Validate field semantics and determine whether the matched object exists.

3

Enrich

Add reputation, prevalence, owner, identity, network, and adjacent-event context.

4

Scope

Search for related execution, persistence, access, and follow-on activity.

Expected benign overlap

Administration, software development, security testing, automation, content inspection, shared infrastructure, or legitimate files may overlap. Tune only after ownership and prevalence are established.

Response boundary

A repository or path match does not prove malware execution, decoded C2 use, compromise, or attribution.

VALIDATION GATES

Controlled tests and promotion criteria.

QUALITY CONTROL

Validation steps

1. Confirm the primary table and every projected field exist.
2. Replay an authorized benign event matching the query shape.
3. Measure at least 30 days of tenant prevalence and benign overlap.
4. Verify every result retains sufficient evidence for triage.

Decision criteria

Success: the test is visible and real matches remain attributable.

Rejection: benign activity dominates or the campaign artifact is no longer reliable.

Failure: required telemetry or fields are unavailable.

Promotion gate

Do not promote to production until telemetry, prevalence, ownership, and false-positive handling are demonstrated in the target environment.

CONCLUSION AND REFERENCES

Coverage statement and document control.

FINAL

CONCLUSION

Hunting query

Hunts GitHub poem-based C2 discovery from compromised AI infrastructure.

A repository or path match does not prove malware execution, decoded C2 use, compromise, or attribution.

MITRE ATT&CK

T1102.003

References

1. CANTO INCOGNITO / POELLM - REFERENCES
2. Published: 2026-10-07
3. Campaign period: at least 2026-04 through publication
4. Prepared: 2026-10-11
5. PRIMARY TECHNICAL RESEARCH
6. Black Lotus Labs, Lumen Technologies
7. Canto incognito: tracking the PoeLLM malware
8. hxxps://www[.]lumen[.]com/blog/en-us/canto-incognito-tracking-the-poellm-malware
9. Published 2026-10-07; accessed 2026-10-11.
10. OFFICIAL SCHEMA DOCUMENTATION
11. Microsoft Learn
12. DeviceNetworkEvents table in the advanced hunting schema

Document control

Canonical locked typography and layout. Only the campaign illustration on page 1 is variable.